

小程序 BLE 扫码核销设备交互协议

V3.0 · 实施版 (硬件 / 固件 / 小程序 / 云函数 / 测试共同基线)

文档用途

规定人脸验证完成后，小程序通过二维码与 BLE 设备建立一次性授权的全部线协议、签名、状态机、错误反馈、断电恢复和验收要求。硬件团队可直接据此实现固件并联调。

项目	值
文档版本	V3.0 / 2026-08-29
对齐服务端	faceRecognition v105
对齐小程序	0.2.48
数据库基线	迁移 066 : BLE qualification / device / authorization
适用业务	正常核销、体验核销
协议传输	微信小程序 BLE Central + GATT 透明传输 ; UTF-8 JSON Lines
密钥算法	HMAC-SHA256 (对称消息认证 ; 不是公钥加密)
密钥与凭据	本文不包含任何真实 BLE 密钥、AppSecret、二维码配对码或用户凭据

最重要结论

设备不得仅凭二维码、蓝牙连接或客户端按钮进入工作状态。只有设备验证服务端 HMAC 授权成功并原子保存会话后，才可把 status 置为 2 ; 服务端也只有确认 status=2 后才核销和生成工单。

1. 规范语言、范围与不可变边界

本文使用“必须 (MUST) ”“禁止 (MUST NOT) ”“建议 (SHOULD) ”表达约束。出现冲突时，MUST / MUST NOT 优先于示例。

1.1 本次包含

- 人脸验证通过后建立 90 秒资格，随后扫码、连接 BLE、读取设备、签发最长 30 秒的一次性设备授权。
- 设备验证授权并进入工作状态 (status=2) 后，小程序回报服务端；服务端再执行原有核销、扣次、工单写入。
- 正常核销与体验核销使用同一设备协议；usage_count 由办理人员选择，范围 1-999。
- 二维码窗口、人脸资格、设备授权、工单之间的状态、超时、重试和错误反馈。
- 断电恢复、提前结束、nonce 防重放、密钥安全存储和量产验收。

1.2 本次不包含

- App 不下发能量、温度、模式、光源、启停或单次服务时长。设备进入工作态后不再按具体项目限制模式。
- 一个核销次数对应多少分钟尚未定稿，必须与米总确认后写入设备受控配置；禁止固件擅自固定为 30 分钟。
- 二维码中的 6 位 code 不是密钥，不提供独立安全性；它只用于服务端核对设备登记记录。
- 当前 v105 未验证设备回执的独立 MAC。本文件给出量产回执 MAC 格式，但须待服务端升级后才能形成端到端密码学闭环。

1.3 业务规则 (简版)

阶段	服务端/小程序	设备	是否扣次
选择	选择门店、客户、项目、次数；老师可选/自动绑定	无动作	否
人脸	1:1 人脸通过后创建 90 秒资格	无动作	否
扫码连接	允许 90 秒内反复打开/关闭二维码窗口	待机 status=1	否
授权签发	锁定本次设备，签发最长 30 秒 HMAC 授权	验证 HMAC / nonce / 时间 / 次数	否
进入工作	收到 status=2 回执后才调用最终核销	原子持久化后 status=2	是 (一次)
完成/恢复	幂等恢复同一工单，二维码永久关闭	继续工作或断电恢复	不得重复

2. 参与方、信任边界与总流程

2.1 参与方

参与方	可信内容	不得信任的内容
小程序	已登录 UID、本机临时进度、微信 BLE API	不能直接扣次、不能生成 HMAC、不能决定设备是否可开机
CloudBase 云函数	数据库、角色/门店权限、余额/体验额度、BLE_AUTH_SIGNIN G_KEY	不能只凭客户端声称的 status=2 视为设备不可伪造证明
BLE 设备	自身 device_id、device_type、当前 nonce、HMAC 密钥、工作状态	二维码 code 和 App 请求本身不可信，必须验 HMAC
二维码	设备静态索引 sn + 6 位兼容配对码	可被拍照复制，不是安全令牌

2.2 端到端顺序 (必须按序)

#	执行方	动作
1	用户	选择门店 / 客户 / 项目 / 次数并完成人脸验证
2	服务端	创建 90 秒 qualification；此时不扣次
3	小程序	人脸成功后才显示“开始设备核销”；打开二维码扫描
4	小程序	解析 nc://bind，开启蓝牙，按 NCM-xxxxxx 搜索并连接
5	小程序 → 设备	发送 get_info；读取 device_id/type/name/status/nonce
6	小程序 → 服务端	提交 qualification + QR + info，请求一次性授权
7	服务端	验证资格/账户/门店/客户/项目/次数/设备登记/nonce，生成 HMAC auth
8	小程序 → 设备	发送 auth；设备验证、持久化会话、置 status=2
9	设备 → 小程序	返回 auth_result；超时则小程序发送 query_status
10	小程序 → 服务端	确认 DEVICE_WORKING；服务端幂等扣次并生成工单
11	小程序	二维码窗口永久关闭，跳转同一核销工单
严禁越级 未完成人脸、qualification 不完整/过期、设备 status 不是 1、设备未登记、类型不匹配、HMAC 无效或 nonce 已用时，设备不得工作，服务端不得扣次。		

3. 标识、格式与归一化

字段	格式 / 示例	约束
sn / device_id	NCM1F0C58D0A00	正则 ^NCM[0-9A-F]{11}\$；大写；两者必须相等
BLE 广播名	NCM-8D0A00	固定为 NCM- + device_id 最后 6 个字符；区分大小写
二维码	nc://bind?sn=NCM1F0C58D0A00&code=382451	sn 大写；code 恰好 6 位十进制数字
device_type	haiyangzhiyun	项目中文名转无声调拼音，小写，移除所有非 a-z0-9，最多 128 字符
nonce	0123456789abcdef0123456789abcdef	16 随机字节编码为 32 位十六进制；每次待机授权周期唯一
qualification token	48 位小写十六进制	仅小程序与服务端使用，不发送给设备
authorization token	48 位小写十六进制	仅小程序与服务端使用，不发送给设备
seq	1 / 2 / 3	请求与对应回执必须相同；本版本固定命令序号
时间	1788000000	Unix epoch 秒，整数；禁止毫秒
usage_count	3	整数 1-999；设备不得默认为 1

3.1 项目名到 device_type 的唯一算法

- 调用无声调拼音转换；按原字符顺序拼接。
- 转换为小写；删除空格、连字符、下划线、标点和所有非 a-z0-9 字符。
- 若结果为空，服务端拒绝建立资格；固件与设备登记值必须完全相同。
- 示例：海洋之蕴 → haiyangzhiyun；魔法柔肤 → mofaroufu；露思康辰 → lusikangchen。

没有 model 字段

本协议不要求 model=WD-BLE，也没有任何 WD-BLE 固定型号判断。device_type 是项目名称归一化结果；设备进入工作态后，它不限制设备端可选模式。

4. BLE / GATT / 串口传输层

4.1 当前小程序的服务发现规则

- 小程序作为 BLE Central；设备作为 Peripheral。BLE 5.4 设备必须向下兼容手机可用的 GATT 能力。
- 设备广播名必须等于 NCM-{SN 后六位}。发现超时 15 秒；连接超时 12 秒。
- 小程序遍历 primary service，要求恰好一个 service 同时具有至少一个 write/writeNoResponse 特征和至少一个 notify/indicate 特征。
- 若没有候选 service，报 BLE_PROTOCOL_CHANNEL_MISSING；若超过一个，报 BLE_PROTOCOL_CHANNEL_AMBIGUOUS。量产固件必须只暴露一个符合条件的业务 service。
- 优先选择支持 write 的特征，否则 writeNoResponse；优先选择 notify 的特征，否则 indicate。

4.2 帧格式

项目	规定
编码	UTF-8
数据结构	单个 JSON object；禁止数组作为顶层
帧结束	每个 JSON 后必须追加一个 LF (0x0A, \n)
接收缓存	必须支持一个 JSON 被拆成多个 BLE 通知，也必须支持一次通知包含多个 JSON；以 LF 切帧
空白	JSON 内允许；LF 前后的空白可忽略
未知字段	接收方应忽略，以保证向后兼容
未知命令	返回 code=404 的 error frame；不得改变设备状态
重复 seq	同一会话同一 seq 的幂等命令应返回原结果，不得重复执行工作状态转换
<pre>{"ver":"1.0","seq":1,"cmd":"get_info","ts":1788000000}</pre>	
ATT MTU / 分片验收 规范允许分片，但当前 0.2.48 将完整 JSON 交给微信 writeBLECharacteristicValue。硬件联调必须在 iOS 与 Android 真机验证 auth 最大帧可成功写入；若模块不能接受长写，发布前必须由 App 增加分片层，禁止在固件中静默截断。	

4.3 设备内部串口（若使用透明传输模块）

建议 USART1：PA9(TX) / PA10(RX)，115200 bps，8N1，无流控；BLE 模块只透明转发 JSON Lines。若硬件不同，可调整物理串口，但线上 JSON 协议不得改变。

5. 二维码、人脸门禁与两个时间窗口

5.1 静态二维码

```
nc://bind?sn=NCM1F0C58D0A00&code=382451
```

- 二维码必须贴在对应设备机身，sn 与设备固件 device_id 必须一致。
- code 在服务端仅以 SHA-256 摘要登记；设备本身不需要读取 code。
- 二维码被复制不能直接开机，因为设备还必须验证服务端 HMAC、当前 nonce 和短时效。

5.2 90 秒 qualification

规则	精确定义
开始	服务端在人脸通过并成功写入 qualification 后，以数据库 CLOCK_TIMESTAMP 计时
剩余时间	必须使用服务端/数据库返回值；客户端本地倒计时只用于显示
可关闭	签发设备授权前，二维码窗口可在 90 秒内反复关闭和打开；关闭不取消资格、不扣次
不可越级	没有有效 qualification 时扫码按钮必须禁用；直接调用服务端也应被拒绝
过期	超过 90 秒后必须重新拍照和人脸验证
成功	设备进入 status=2 并生成工单后永久关闭，不得再次打开

5.3 最长 30 秒设备授权

服务端签发 $expire_at = \min(issued_at + 30 \text{ 秒}, qualification.expires_at)$ 。设备必须在这个窗口内验证并进入 status=2；不是固定 30 秒，也不能超过剩余人脸资格时间。

典型剩余时间

若人脸资格只剩 7 秒，设备授权也最多 7 秒。任何显示 56480 秒之类的值都是毫秒/秒或时区换算错误，必须按 Unix 秒和数据库剩余时间修复。

6. HMAC-SHA256：唯一生效的授权算法

不是公钥加密

当前没有 public key / private key，也不使用 RSA、ECDSA 或 AES 来签发开机授权。HMAC-SHA256 使用同一份对称密钥验证消息真实性与完整性；它不加密 JSON 内容。

6.1 密钥生成与字节解释

openssl rand -hex 32

- 命令生成 32 个随机字节，并以 64 个小写十六进制字符输出。
- 当前 faceRecognition v105 把这 64 个字符作为 UTF-8/ASCII 密钥字节直接传给 HMAC；设备必须做同样处理。禁止把 64 字符 hex 再解码为 32 raw bytes，否则签名不同。
- 同一 64 字符值写入云函数环境变量 BLE_AUTH_SIGNING_KEY 和每台设备安全存储。
- 密钥长度按 UTF-8 至少 32 字节；建议始终使用上述 64 字符格式。

6.2 什么是设备安全存储

允许	禁止
Secure Element / TrustZone / OTP / 读保护 Flash / 加密 NVS / 安全分区	普通可读配置文件、日志、串口打印、二维码、BLE 广播、App 本地存储
量产工装在受控环境一次写入；写后启用读保护、关闭调试读回	通过小程序、普通 BLE provision 命令或客服聊天下发真实密钥
固件只允许 HMAC 运算接口使用密钥，不提供读取 API	把密钥提交到 Git、云函数 ZIP README、截图或测试报告

6.3 当前 canonical string (字段名、顺序完全固定)

command=enter_work&device_id=<DEVICE_ID>&device_type=<DEVICE_TYPE>&usage_count=<INTEGER>&expire_at=<UNIX_SECONDS>&issued_at=<UNIX_SECONDS>&nonce=<32_HEX>

- UTF-8 编码；字段名全小写；顺序不得改变；不加 JSON 引号；不做 URL 编码；末尾无 &、无换行。
- signature = lowercase_hex(HMAC-SHA256(key_utf8, canonical_utf8))，固定 64 位小写十六进制。
- 数字必须是十进制整数文本，不能出现 3.0、前导 +、科学计数法或空格。
- 设备比较签名时必须使用 constant-time comparison。

6.4 可复现测试向量 (仅测试，严禁量产)

key_utf8 = 000102030405060708090a0b0c0d0e0f101112131415161718191a1b1c1d1e1f
canonical = command=enter_work&device_id=NCM1F0C58D0A00&device_type=haiyangzhiyun&usage_count=3&expire_at=1788000030&issued_at=1788000000
&nonce=0123456789abcdef0123456789abcdef
signature = 9515e2bc39f5bf22b73285d6f747ddecea2101034e98d1409417ff07042e75c1

量产安全缺口

当前设备 auth_result/status 没有被 v105 独立验 MAC。HMAC 已保护“服务端→设备”的开机授权，但“设备→服务端”的工作回执仍经客户端转发。第 12 节规定了兼容扩展字段；服务端升级验证前，不得宣称端到端完全防伪。

7. 线上 JSON 通用结构

字段	类型	必填	含义 / 验证
ver	string	是	固定 1.0；不接受空值
seq	integer	是	get_info=1，auth=2，query_status=3；回执必须原样返回
cmd	string	是	命令或回执类型；区分下划线，建议全小写
ok	boolean	回执	成功必须 true；失败必须 false
code	integer	失败	错误码；成功可省略或为 0
message	string	失败建议	简短英文/中文诊断，不得包含密钥、完整 HMAC 或内部栈

7.1 接收方处理顺序

- 先按 LF 切帧，再 UTF-8 解码和 JSON parse；任何半帧都不得提前解析。
- 验证顶层 object、ver、seq、cmd；随后验证命令专属字段。
- 失败必须返回结构化错误，不得仅返回字符串或静默断开。
- 收到无法解析的 JSON 可返回 400；不得改变 nonce、status 或持久化会话。
- 设备不能因未知额外字段失败；这样可兼容量产 receipt_signature 扩展。

8. 小程序 → 设备：全部命令

8.1 get_info (seq=1)

{ "ver": "1.0", "seq": 1, "cmd": "get_info", "ts": 1788000000 }		
字段	类型	规则
ver	string	固定 1.0
seq	integer	固定 1
cmd	string	固定 get_info
ts	integer	手机 Unix 秒；仅供诊断/无 RTC 模式建立短时参考，不能替代 HMAC

设备收到后不得进入工作状态；只读取当前身份、状态和本次 nonce，并返回 info。小程序等待 10 秒。

8.2 auth (seq=2)

{ "ver": "1.0", "seq": 2, "cmd": "auth", "auth": { "command": "enter_work", "device_id": "NCM1F0C58D0A00", "device_type": "haiyangzhiyun", "nonce": "0123456789abcdef0123456789abcdef", "usage_count": 3, "issued_at": 1788000000, "expire_at": 1788000030, "signature": "9515e2bc39f5bf22b73285d6f747ddecea2101034e98d1409417ff07042e75c1" } }		
auth 字段	类型	设备必须验证
command	string	必须 enter_work
device_id	string	必须等于本机 SN
device_type	string	必须等于本机登记类型；仅授权前校验
nonce	string	必须等于当前待机 nonce，且从未使用
usage_count	integer	1-999，且设备能力允许；不得强制等于 1
issued_at	integer	Unix 秒；与 expire_at 构成已签名窗口
expire_at	integer	必须 > issued_at，且窗口不超过 30 秒；接收时未过期
signature	string	64 位小写 hex；按第 6 节重算并常量时间比较

小程序等待 auth_result 最多 20 秒；超时不会立即扣次，而是发送 query_status 查询真实状态。

8.3 query_status (seq=3)

{ "ver": "1.0", "seq": 3, "cmd": "query_status" }

只查询状态，不改变状态、不刷新 nonce、不延长授权。小程序等待 status 最多 5 秒。

8.4 当前 App 不发送的命令

命令	状态
control / set_mode / set_energy / set_temperature	禁止：业务 App 不控制设备参数
stop	当前不发送；客户提前结束由设备本地操作
provision	生产 App 不发送；密钥不得通过普通 BLE 配网
refund / restore_unit	禁止：设备无权退款或改变业务余额

9. 设备 → 小程序：全部期望回执

9.1 info (响应 seq=1)

```
{ "ver": "1.0", "seq": 1, "cmd": "info", "ok": true, "device_id": "NCM1F0C58D0A00", "device_type": "haiyangzhiyun", "ble_name": "NCM-8D0A00", "status": 1, "nonce": "0123456789abcdef0123456789abcdef", "ts": 1788000001 }
```

字段	类型	小程序验证 / 设备要求
cmd	string	info 或兼容值 get_info_result
seq	integer	必须 1
ok	boolean	成功 true；失败 false
device_id	string	必须与二维码 sn 相等
device_type	string	必须与本次 expectedDeviceType 相等
ble_name	string	必须等于 NCM-{sn 后 6 位}
status	integer	1=待机；2=工作中；其他值拒绝
nonce	string	32 位 hex；status=1 时必须为未使用的当前随机数
ts	integer	设备时间；当前小程序不强制，但建议用于诊断

9.2 auth_result 成功 (响应 seq=2)

```
{ "ver": "1.0", "seq": 2, "cmd": "auth_result", "ok": true, "device_id": "NCM1F0C58D0A00", "device_type": "haiyangzhiyun", "nonce": "0123456789abcdef0123456789abcdef", "usage_count": 3, "status": 2 }
```

- status 必须为 2，ok 必须为 true；仅此组合表示设备已经进入工作状态。
- device_id、device_type、nonce 必须与 auth 完全一致。当前小程序会用 readInfo 的值补齐缺失字段，但量产固件必须完整返回。
- 设备必须先把手会话与工作状态写入非易失存储，再发送成功回执；顺序不可颠倒。

9.3 auth_result 失败 (响应 seq=2)

```
{ "ver": "1.0", "seq": 2, "cmd": "auth_result", "ok": false, "code": 1001, "message": "invalid signature", "status": 1 }
```

失败回执必须保持 status=1（或当前真实非工作态），不得消耗 nonce 后又声称失败；若 nonce 已被安全消耗但未进入工作态，设备必须使用明确恢复策略并返回可诊断错误。

9.4 status (响应 seq=3)

```
{ "ver": "1.0", "seq": 3, "cmd": "status", "ok": true, "device_id": "NCM1F0C58D0A00", "device_type": "haiyangzhiyun", "nonce": "0123456789abcdef0123456789abcdef", "usage_count": 3, "status": 2 }
```

查询只返回当前真实状态。status=2 时必须保留最初授权使用的 device_id/type/nonce/usage_count，供断线和断电后的同会话恢复。

9.5 通用 error frame

```
{ "ver": "1.0", "seq": 9, "cmd": "error", "ok": false, "code": 404, "message": "unsupported command" }
```

10. 设备状态机与原子性

状态	数值	允许命令	进入条件	离开条件
OFF/未就绪	0	get_info, query_status	上电自检失败/未就绪	自检和安全存储可用
READY/待机	1	get_info, auth, query_status	空闲且已登记	有效 auth 原子提交，或本地停机
WORKING/工作	2	get_info, query_status	HMAC 验证成功且会话持久化	服务正常结束或本地提前结束

10.1 status=1 → 2 的原子顺序

- 验证 ver/cmd/device_id/device_type/status/usage_count/issued_at/expire_at/nonce/signature 全部通过。
- 以事务或断电安全写入：session_id (可内部生成)、nonce、usage_count、unit_duration_sec 配置版本、工作参数快照、状态=WORKING。
- 把 nonce 标记为已使用；写入失败则保持/恢复 status=1，并返回失败。
- 确认非易失写成功后才启动输出/计时，再发送 auth_result ok=true,status=2。

10.2 幂等与重复包

输入	设备行为
同一 auth 在 status=1 再次到达	若第一次未提交，正常验证；若 nonce 已用则返回 1004
同一 auth 在对应 status=2 到达	不得再次启动/累计次数；返回同一成功结果或 1005，但不得改变会话
不同 auth 在 status=2 到达	返回 1005 busy
重复 query_status	返回同一当前状态，无副作用
App 重复确认服务端	服务端以 authorization/idempotency key 恢复同一工单，不得重复扣次

10.3 设备进入工作态后的项目选择

授权前 device_type 必须与所选项目一致，用于设备兼容性与登记校验；一旦 status=2，设备不再按项目限制具体模式，操作者可在设备端自由选择该设备支持的项目/模式。usage_count 仍是本次授权总次数。

11. 断电恢复、正常完成与提前退出

11.1 必须持久化的最小状态

字段	要求
session_state	READY / WORKING / COMPLETED / ENDED_EARLY
device_id / device_type	当前授权绑定值
nonce	当前授权 nonce 及 used 标志
usage_count	本次授权单位数
unit_duration_sec / config_version	受控本地配置；时长未定稿前不得写死
completed_units / remaining_units	已完成与剩余单位；更新需断电安全
remaining_seconds_in_unit	当前单位剩余时间；按固件耐久策略周期保存
mode snapshot	恢复时需要的设备参数；不发送给业务 App
last_update / boot_counter	诊断和防回滚

11.2 断电恢复

- 设备在确认 auth 前必须写入 WORKING；断电重启读取到 WORKING 时，直接恢复到上一次会话，而不是退回 READY。
- 恢复后的 get_info/status 仍返回 status=2、原 nonce 和 usage_count；小程序可恢复同一授权并生成同一工单。
- 不得因为重启生成新 nonce 覆盖尚未完成的 WORKING 会话；不得再次消耗业务次数。
- 若持久化记录校验失败，设备必须安全停机并返回明确故障，不得猜测状态继续输出。

11.3 提前退出

- 用户可在设备本地选择“结束本次服务”；当前 App 不发送 stop 命令。
- 设备安全停止输出，记录 ENDED_EARLY/COMPLETED，再切换到 READY 并生成全新 nonce。
- 服务端已在首次 status=2 时完成核销，提前退出不会自动退款或返还次数。业务退款必须走原有退费审批。

服务时长待定

一个 usage_count 对应的实际服务分钟数由米总确认。固件必须将其作为受控配置，而不是把 30 分钟写死在协议或代码；联调可使用测试配置，但不得冒充正式业务参数。

12. 量产回执签名扩展 (向后兼容，服务端升级后强制)

当前 0.2.48 会忽略未知字段，因此固件现在可以附带以下字段；但 faceRecognition v105 尚未验证它们。量产上线前应升级服务端，使 auth_result/status 的设备证明也通过 HMAC 验证。

12.1 建议新增字段

字段	类型	要求
usage_count	integer	与 auth 相同
receipt_ts	integer	设备生成回执时 Unix 秒，或受控会话时间
receipt_counter	integer	设备单调递增计数器，持久化，防回放
receipt_signature	string	64 位小写 HMAC-SHA256 hex

12.2 auth_result canonical (建议 V2.1)

```
cmd=auth_result&seq=2&ok=true&device_id=<ID>&device_type=<TYPE>&nonce=<NONCE>&status=2&usage_count=<COUNT>&receipt_ts=<TS>&receipt_counter=<COUNTER>
```

12.3 status canonical (建议 V2.1)

```
cmd=status&seq=3&ok=true&device_id=<ID>&device_type=<TYPE>&nonce=<NONCE>&status=<0|1|2>&usage_count=<COUNT>&receipt_ts=<TS>&receipt_counter=<COUNTER>
```

上线门槛
在服务端没有验证 receipt_signature、counter 和 replay ledger 前，这些字段只是兼容预埋，不能单独证明工作回执来自真实设备。硬件、服务端和测试必须共同完成一次版本切换。

13. 设备错误码（设备必须返回，小程序已能解释）

code	符号	含义	处理
400	BAD_REQUEST	JSON/字段/类型无法识别	修正固件帧格式；不扣次
403	FORBIDDEN	设备策略拒绝	检查设备状态/权限；不扣次
404	UNSUPPORTED_COMMAND	命令不支持	升级固件；不扣次
1001	INVALID_SIGNATURE	HMAC 不一致	核对 key 字节解释和 canonical 顺序；不扣次
1002	AUTH_EXPIRED	授权已过期/窗口非法	重新人脸后再办；不扣次
1003	NONCE_MISMATCH	auth nonce 不是当前 nonce	重新读取设备；不扣次
1004	NONCE_USED	nonce 已使用	禁止重放；核对已有会话
1005	DEVICE_BUSY	设备正在工作	不得再次授权；查询原会话
1006	DEVICE_ID_MISMATCH	授权 ID 与本机不一致	检查二维码/登记；不扣次
1007	DEVICE_TYPE_MISMATCH	授权类型与本机不一致	更换正确设备；不扣次
1008	UNSUPPORTED_OPERATION	不支持 enter_work	升级固件；不扣次
1009	NOT_PROVISIONED	设备未完成安全配置	返厂/管理员配置；不扣次
1011	INVALID_USAGE_COUNT	次数非整数/越界/设备不支持	重新选择合法次数；不扣次

13.1 错误回执统一格式

```
{ "ver": "1.0", "seq": 2, "cmd": "auth_result", "ok": false, "code": 1002, "message": "authorization expired", "status": 1 }
```

- 错误必须关联原 seq；message 不得包含密钥、完整签名、内存地址或调试栈。
- 错误返回前必须保持安全状态；任何拒绝都不得启动设备。
- 设备若已经原子进入 status=2，即使通知发送失败，也必须让 query_status 返回 2，不能回滚为 1。

14. 小程序/服务端错误反馈与是否可重试

错误	用户反馈	可重试	是否扣次
BLE_QR_CANCELLED / WINDOW_CLOSED	扫码窗口已关闭；90 秒内可重开	是（未签发 auth）	否
BLE_QR_INVALID	不是有效设备二维码	是	否
BLE_SWITCH_OFF	手机蓝牙未开启	是	否
BLE_DEVICE_NOT_FOUND	15 秒未找到广播名	是	否
BLE_CONNECTION_FAILED	连接失败/被占用	是	否
BLE_PROTOCOL_CHANNEL_MISSING	缺少写+通知通道	固件修复后	否
BLE_PROTOCOL_CHANNEL_AMBIGUOUS	多个业务通道，无法安全选择	固件修复后	否
BLE_INFO_TIMEOUT	10 秒无 info	是	否
BLE_DEVICE_ID/TYPE/NAME_MISMATCH	二维码、登记或设备不匹配	换正确设备	否
BLE_NONCE_INVALID / NONCE_REUSED	随机数格式或重放失败	设备复位/诊断后	否
BLE_QUALIFICATION_EXPIRED	90 秒资格过期	重新人脸	否
BLE_AUTHORIZATION_ALREADY_ISSUED	同一资格已锁定设备，禁止重发	查询原设备状态	否
BLE_AUTH_RESULT_TIMEOUT	20 秒无回执，系统转 query_status	自动核对	尚未确认
BLE_DEVICE_NOT_WORKING	设备未确认 status=2	按错误处理	否
BLE_ALREADY_FINALIZED	已生成工单	打开原工单	已经一次

反馈原则
任何失败必须告诉用户：发生在哪一步、是否扣次、能否重试、下一步做什么。不得把 Cannot read properties、SQLSTATE、堆栈或 undefined 直接显示给业务用户。

15. 超时、断线、关闭窗口与恢复矩阵

发生点	系统状态	允许动作	禁止动作
人脸后、未扫码	qualification ACTIVE	90 秒内重开扫码	扣次/建工单
已连设备、未签 auth	qualification ACTIVE	关闭连接后重扫同/其他合格设备	设备开机
auth 已签发、未发设备	authorization ISSUED	仅恢复同设备；管理员诊断	更换设备/重复签发/延时
auth 已发送、无回执	未知	query_status；status=2 则恢复	盲目重发 auth
设备 status=2、服务端未确认	DEVICE_WORKING	本机持久进度恢复并确认	选择其他客户/设备
服务端已生成工单	FINALIZED	打开同一工单	再次扫码/再次扣次
设备断电	持久化 WORKING	重启继续、status 仍为 2	生成新 nonce 覆盖会话
客户提前结束	ENDED_EARLY→READY	安全停机并生成新 nonce	自动退款

15.1 本机进度记录

小程序按登录 UID 保存 qualificationToken、authorizationToken、deviceId/type/nonce、deviceResult 和状态。它只用于恢复，不能作为服务端信任根；换微信、清缓存或换手机后，服务端仍必须拒绝任何不匹配的确认。

16. 出厂配置、设备登记与密钥轮换

16.1 每台设备出厂记录

字段	示例/说明	保存位置
device_id / qr_sn	NCM1F0C58D0A00	设备安全配置 + 服务端设备表 + 二维码
ble_name	NCM-8D0A00	设备广播配置 + 服务端设备表
device_type	haiyangzhiyun	设备安全配置 + 服务端设备表
pairing_code	382451	二维码明文；服务端只存 SHA-256
BLE_AUTH_SIGNING_KEY	64 hex chars	设备安全存储 + 云函数环境变量；绝不进二维码/设备表
unit_duration_sec	TBD	设备受控配置；米总确认后下发
firmware_version	厂商定义	设备诊断信息/生产记录

16.2 配置流程

- 在离线/受控量产工装生成或领取密钥；严禁用小程序普通 BLE 链路写入。
- 写入设备安全存储，启用读保护，关闭调试读取；执行 HMAC 自检向量。
- 生成二维码并把 pairing_code 的 SHA-256、设备身份、类型、广播名登记到服务端。
- 上线前执行第 18 节验收；验收报告只记录 key_id/批次，不记录真实密钥。

16.3 轮换

当前 v105 只读取一个 BLE_AUTH_SIGNING_KEY，没有 key_id 在线选择。轮换必须协调云函数与设备批次，安排双钥过渡或停机窗口；在服务端支持 key_id 前，禁止单方面改云端或设备端密钥。

17. 小程序与服务端内部接口（供联调定位，非设备线协议）

动作	小程序提交	服务端返回 / 效果
createVerificationBleQualification	门店、客户、项目、老师(可选/本人)、类型、unitCount、人脸证据	qualificationToken、expiresAt、expectedDeviceType ；90 秒；不扣次
issueVerificationBleAuthorization	qualificationToken、qrSn、qrCode、deviceInfo	authorizationToken + authCommand；最长 30 秒；锁定同一设备
confirmVerificationBleWorkStarted	authorizationToken + deviceResult status=2	幂等核销、扣次、生成 verificationId/code
recover	clientRequestId / authorization	恢复同一工单，不重复写入

17.1 服务端签发前必须验证

- 当前登录 UID、角色、门店、办理人员、客户、项目、核销类型、次数与人脸证据。
- 正常核销余额或体验额度；体验核销仅老师发起；门店业务老师可选。
- qualification 属于当前账号/门店且未过期；未完成、未签发其他授权。
- 设备登记 ACTIVE；sn/id/type/name/code hash 全部匹配；status=1；nonce 合法且未用。
- HMAC key 存在且 UTF-8 长度至少 32 字节。

客户端无权写数据库
BLE 三张表启用 RLS；anon/authenticated 无表、序列访问；只有 service_role 可写。小程序不得直接插入资格、设备或授权，也不得直接扣次。

18. 硬件 / 固件 / App 联合验收清单

编号	测试	期望
T01	正常：人脸→扫码→get_info→auth→status=2	只生成 1 张工单，只扣选择的 usage_count
T02	未人脸直接扫码/调用	UI 禁止；服务端拒绝；设备不工作
T03	qualification 超过 90 秒	不能再打开/签发；重新人脸
T04	剩余资格 7 秒	auth expire_at 不超过 7 秒
T05	HMAC 改 1 位	设备 1001，status 保持 1
T06	canonical 字段顺序错误	设备 1001
T07	把 hex key 解码为 raw bytes	测试向量不匹配；修正为 UTF-8 64 字符
T08	nonce 旧值/重复值	1003/1004，不工作
T09	device_id/type/name 与二维码不一致	客户端/服务端拒绝
T10	设备 status=2 再授权	1005，不重复启动
T11	auth_result 通知丢失	query_status 返回 2；恢复同一工单
T12	query_status 也超时	不扣次；显示可诊断错误；不得盲重发 auth
T13	status=2 后 App 崩溃/换页	本机恢复并生成同一工单
T14	工作中断电	重启恢复原状态/次数/剩余时间；status=2
T15	客户提前结束	本地安全停机，生成新 nonce；不自动退款
T16	usage_count=1/3/999	设备按整数接受能力范围；不得固定 1
T17	usage_count=0/1.5/1000	1011
T18	多个 write+notify service	App 报 AMBIGUOUS；固件只保留一个业务通道
T19	auth JSON 跨 BLE 分片	设备缓存至 LF 后正确解析
T20	一次通知包含两帧	App/设备逐帧解析，不粘包
T21	普通微信号/换手机	仍需业务账号绑定；本地记录不能越权恢复
T22	相同 confirm 重放 10 次	服务端恢复同一工单，不重复扣次
T23	正常核销与体验核销各走一遍	设备协议一致，服务端额度来源正确
T24	iOS/Android 真机最大 auth 帧	写入成功；不得出现 MTU 截断

19. 量产发布门槛与责任边界

责任方	必须完成
硬件/固件	唯一 GATT 业务通道；HMAC 测试向量；nonce CSPRNG；断电安全持久化；错误码；长帧/分片；提前退出
后端	迁移 066 READY；设备登记；BLE_AUTH_SIGNING_KEY；90/30 秒数据库约束；幂等核销；禁止客户端写表
小程序	严格人脸门禁；剩余时间用服务端值；结构化中文错误；扫码关闭/重开；status=2 后跳同一工单
安全	密钥注入/读保护/日志检查；回执 MAC 服务端验证方案；威胁模型与轮换预案
QA	第 18 节 24 项真机验收，覆盖 iOS/Android、断电、弱网、通知丢失、重复包

19.1 当前可以确认的安全边界

- 服务端签发的 enter_work 授权由 HMAC-SHA256 保护；密钥不进入小程序或二维码。
- 资格与授权短时效、单设备锁定、nonce 和数据库唯一约束减少重放与换机绕过。
- 只有设备 status=2 才执行既有原子核销，服务端确认幂等。
- 设备回执尚未由服务端独立验 MAC，是当前最重要的剩余风险。
- 当前协议不提供业务 JSON 内容加密；如需机密性，另行评估 BLE Secure Connections 或应用层 AES-GCM，不能把 HMAC 当加密。

最终签字条件

固件、后端、小程序和 QA 必须使用同一版本文档和同一 HMAC 测试向量。任何字段、canonical 顺序、时效、状态值或 key 字节解释变化，都必须升协议版本并重新做跨端验收。

附录 A：一眼可执行的设备实现清单

- [] device_id 符合 NCM + 11 位大写十六进制；BLE 名称为 NCM- + 后 6 位。
- [] device_type 为项目名全小写无声调拼音，删除所有分隔符；没有 model 字段。
- [] 唯一业务 GATT service：至少一个 write 与一个 notify；不会出现第二候选。
- [] UTF-8 JSON Lines；缓存分片，按 LF 拆帧；不会把半帧当 JSON。
- [] get_info/info、auth/auth_result、query_status/status 四组交互字段完全匹配。
- [] HMAC-SHA256；key 是 64 个 hex 字符的 UTF-8 字节；canonical 顺序严格固定。
- [] nonce 是 16 字节 CSPRNG → 32 hex；每次授权唯一；持久化 used 标志。
- [] auth 时间窗口 1–30 秒；设备拒绝过期；usage_count 为 1–999 整数。
- [] 先持久化 WORKING 会话，再置 status=2、启动设备、发成功回执。
- [] 断电恢复原会话；提前退出可用；不会因为重启重复计次。
- [] 错误按 400/403/404/1001...1011 返回结构化 JSON；失败不启动。
- [] 密钥处于安全存储，无法通过 BLE/UART 日志/调试口/普通 API 读出。
- [] 通过第 18 节全部测试，尤其是 iOS/Android 长帧、通知丢失和断电测试。

附录 B：当前实现来源（审计定位）

内容	仓库路径
服务端签名与 BLE 状态	cloudfunctions/faceRecognition/index.js
小程序 BLE 收发与错误	miniprogram-app/miniprogram/services/ble-verification.js
页面 90 秒门禁与跳转	miniprogram-app/miniprogram/pages/verification/
BLE 数据库约束	database/migrations/066_ble_verification_authorization.sql
只读验收	database/cloudbase-console/066-readonly-verify.sql
跨端契约测试	tests/ble-verification-contract.test.js
最终业务规则	PROJECT_CONTEXT.md

文档结束

本 PDF 是硬件交互实施基线，不携带真实密钥。交付固件时请在版本说明中写明“兼容 Lusizhuoer BLE Protocol V3.0”并附第 18 节测试报告。